

IAM

Authentifizierungsprotokolle

Prof. Dr. Annett Laube, HS 2025, HSLU

Was ist ein Authentifizierungsprotokoll?

- (Kryptographisches) Computerkommunikationsprotokoll für die Übertragung von Authentifizierungsdaten zwischen zwei Einheiten
- Voraussetzung für **sichere Kommunikation** innerhalb von Computernetzwerken und Applikationen
- Verwendung:
  - **Anmeldung am System**: Authentifizierung eines Subjektes beim Zugriff auf ein System oder eine Anwendung.
  - **Netzwerkauthentifizierung**: Authentifizierung von Subjekten, die auf Netzwerkressourcen zugreifen.
  - **Transaktionsauthentifizierung**: Authentifizierung für spezifische Transaktionen oder Aktionen innerhalb eines Systems.
  - …

Protokollprinzipien

1. An einem Protokoll müssen zwei oder mehr Parteien beteiligt sein und jeder, der am Protokoll beteiligt ist, muss das Protokoll im Voraus kennen.

2. Alle beteiligten Parteien müssen das Protokoll befolgen.

3. Ein Protokoll muss eindeutig sein – jeder Schritt muss genau definiert sein.

4. Ein Protokoll muss vollständig sein – es muss eine festgelegte Aktion für jede mögliche Situation enthalten.

Eigenschaften von Authentifizierungsprotokollen

- Sicherheit
  - Schutz vor Angriffe, wie Replay-Attacken z.B. durch Verwendung von Nonces
  - Garantieren „Freshness“
- Integrität und Vertraulichkeit
    - durch sichere Kanäle (TLS, Backchannel)
    - digitale Signaturen oder Verschlüsselung
- Benutzerfreundlichkeit
- Skalierbarkeit
- Interoperabilität & Flexibilität
- Compliance & Auditierbarkeit

Wichtige Authentifizierungsprotokolle

- **Web-Authentifizierung & -Autorisierung:**
  - **OAuth**: für Web- und mobile Anwendungen; es erlaubt, Dritten Zugriff auf Ressourcen zu geben.
  - **OpenID Connect (OIDC):** Erweiterung von OAuth 2.0, fügt Authentifizierung für Web- und Smartphone-Anwendungen hinzu.
  - **SAML (Security Assertion Markup Language):** XML-basiertes SSO-Protokoll, zur Authentifizierung und Autorisierung bei Web-Anwendungen.

- **Verzeichnisbasierte Authentifizierung und Zugriffskontrolle:**
  - **LDAP (Lightweight Directory Access Protocol):** Netzwerkprotokoll für den Zugriff auf und die Verwaltung von Verzeichnisdiensten, oft genutzt für die Authentifizierung von Benutzern in Unternehmensnetzwerken.
  - **Kerberos**: Authentifizierungsprotokoll innerhalb eines Netzwerks, häufig in Windows-Domänenumgebungen und für den sicheren Netzwerkzugriff genutzt.